SAINT SECURITY SCANNER - EXECUTIVE ASSESSMENT REPORT

Target: https://app.uat.letshego.com | Authentication: Web Form Credentials | Generated: 2026-10-17 01:53:31

Executive Summary & Risk Overview

This executive security report summarizes the automated vulnerability assessment conducted against **https://app.uat.letshego.com** using the SAINT multi-engine intelligence framework. A total of **19** security findings were identified and verified across the target perimeter, comprising **0 Critical**, **0 High**, **13 Medium**, and **3 Low** risk items. Immediate remediation is advised for all High and Critical findings.

Total Findings	19	**Critical**	0	**High**	0
Medium	13	**Low**	3	**Informational**	3

Detailed Vulnerability Findings & Actionable Recommendations

[MEDIUM]	**1. CSP: Failure to Define Directive with No Fallback**
Endpoint / Host:	https://app.uat.letshego.com
Description:	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
Recommendation:	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
References:	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

[MEDIUM]	**2. CSP: Wildcard Directive**
Endpoint / Host:	https://app.uat.letshego.com
Description:	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Recommendation:	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
References:	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

[MEDIUM]	**3. CSP: script-src unsafe-inline**
Endpoint / Host:	https://app.uat.letshego.com
Description:	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Recommendation:	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
References:	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

[MEDIUM]	4. CSP: style-src unsafe-inline
Endpoint / Host:	https://app.uat.letshego.com
Description:	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Recommendation:	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
References:	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

[MEDIUM]	5. Sub Resource Integrity Attribute Missing
Endpoint / Host:	https://app.uat.letshego.com
Description:	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
Recommendation:	Provide a valid integrity attribute to the tag.
References:	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity

[MEDIUM]	6. CSP: Failure to Define Directive with No Fallback
Endpoint / Host:	https://app.uat.letshego.com/logo192.png
Description:	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
Recommendation:	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
References:	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

[MEDIUM]	7. CSP: Wildcard Directive
Endpoint / Host:	https://app.uat.letshego.com/logo192.png
Description:	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Recommendation:	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
References:	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

[MEDIUM]	8. CSP: script-src unsafe-inline
Endpoint / Host:	https://app.uat.letshego.com/logo192.png
Description:	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Recommendation:	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
References:	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

[MEDIUM]	9. CSP: style-src unsafe-inline
Endpoint / Host:	https://app.uat.letshego.com/logo192.png
Description:	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Recommendation:	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
References:	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

[MEDIUM]	10. CSP: Failure to Define Directive with No Fallback
Endpoint / Host:	https://app.uat.letshego.com/sitemap.xml
Description:	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
Recommendation:	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
References:	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

[MEDIUM]	11. CSP: Wildcard Directive
Endpoint / Host:	https://app.uat.letshego.com/sitemap.xml
Description:	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Recommendation:	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
References:	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

[MEDIUM]	12. CSP: script-src unsafe-inline
Endpoint / Host:	https://app.uat.letshego.com/sitemap.xml
Description:	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Recommendation:	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
References:	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

[MEDIUM]	13. CSP: style-src unsafe-inline
Endpoint / Host:	https://app.uat.letshego.com/sitemap.xml
Description:	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Recommendation:	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
References:	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

[LOW]	14. In Page Banner Information Leak
Endpoint / Host:	https://app.uat.letshego.com/logo192.png
Description:	The server returned a version banner string in the response content. Such information leaks may allow attackers to further target specific issues impacting the product and version in use.
Recommendation:	Configure the server to prevent such information leaks. For example: Under Tomcat this is done via the "server" directive and implementation of custom error pages. Under Apache this is done via the "ServerSignature" and "ServerTokens" directives.
References:	https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/

[LOW]	15. In Page Banner Information Leak
Endpoint / Host:	https://app.uat.letshego.com/sitemap.xml
Description:	The server returned a version banner string in the response content. Such information leaks may allow attackers to further target specific issues impacting the product and version in use.
Recommendation:	Configure the server to prevent such information leaks. For example: Under Tomcat this is done via the "server" directive and implementation of custom error pages. Under Apache this is done via the "ServerSignature" and "ServerTokens" directives.
References:	https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/

[LOW]	16. Open Network Ports and Services Detected
Endpoint / Host:	https://app.uat.letshego.com
Description:	Port scanning identified active listening ports on the target infrastructure. Scan Output Summary: Starting Nmap 7.93 (https://nmap.org) at 2026-10-17 01:53 UTC Nmap scan report for app.uat.letshego.com (13.246.218.101) Host is up (0.045s latency). rDNS record for 13.246.218.101: ec2-13-246-218-101.af-south-1.compute.amazonaws.com Not shown: 99 filtered tcp ports (no-response) Some closed ports may be reported as filtered due to --defeat-rst-ratelimit PORT STATE SERVICE 443/tcp open https
Recommendation:	Audit exposed network services and close any unnecessary ports or management interfaces facing external networks.
References:	https://nmap.org/book/man-port-scanning.html

[INFORMATIONAL]	17. Re-examine Cache-control Directives
Endpoint / Host:	https://app.uat.letshego.com
Description:	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
Recommendation:	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
References:	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/

[INFORMATIONAL]	**18. Modern Web Application**
Endpoint / Host:	https://app.uat.letshego.com
Description:	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
Recommendation:	This is an informational alert and so no changes are required.
References:	

[INFORMATIONAL]	**19. Re-examine Cache-control Directives**
Endpoint / Host:	https://app.uat.letshego.com/robots.txt
Description:	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
Recommendation:	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
References:	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/